

BUG REPORT — HW06 API Testing

SV **Ninh Văn Khải — 23127060** | SUT: EShop @ 85af3ba | Đề bài mục 6.5

Mọi bug trong tài liệu này đều **tái hiện được bằng request thật**. Phần `curl` và phần response ở từng mục được trích thẳng từ `bugs/evidence/<ID>.md` — là kết quả của một lần chạy thật bằng `scripts/capture_bug_evidence.py`, em không gõ tay.

Nội dung bên trong khối `curl` và khối response là nguyên văn của lần chạy thật, kể cả phần tiếng Việt không dấu do chính máy chủ trả về.

Chạy lại toàn bộ bằng chứng:

```
python3 agent-skill1/eshop-api-23127060/scripts/capture_bug_evidence.py
--base-url http://localhost:4000 --shop-bugs/evidence
--api-url http://localhost:4000/api/eshop-api/back-end
```

1. Bảng tổng hợp

ID	Mức độ	Tiêu đề	API	Vi phạm	Bảng chứng	GitHub Issue
A-01	Critical	POST <code>/api/forgot-password</code> trả thẳng mã OTP trong response body	API-1	SEC-07, FR-03	A-01.md (evidence/A-01.md)	<điền link>
A-07	Critical	Mật khẩu lưu plaintext và bị trả về trong response của <code>login / users/me</code>	API-1	SEC-01	A-07.md (evidence/A-07.md)	<điền link>
B-01	Critical	<code>checkout</code> tin tuyệt đối <code>total_amount</code> do client gửi	API-2	FR-08	B-01.md (evidence/B-01.md)	<điền link>
B-01b	Critical	<code>checkout</code> chấp nhận <code>total_amount</code> âm	API-2	FR-08	B-01b.md (evidence/B-01b.md)	<điền link>
B-02	Critical	GET <code>/api/orders/:id</code> thiếu hân xác thực - IDOR	API-2	SEC-02	B-02.md (evidence/B-02.md)	<điền link>
B-03	Critical	PUT <code>/api/admin/orders/:id/status</code> không kiểm tra <code>role</code>	API-2	SEC-03, FR-12	B-03.md (evidence/B-03.md)	<điền link>
B-05	Critical	Công thức giảm giá <code>percent</code> sai dấu, cho ra số tiền giảm ÂM	API-2	FR-09	B-05.md (evidence/B-05.md)	<điền link>
B-07	Critical	<code>apply-coupon</code> không xác thực; bỏ <code>user_id</code> là bỏ qua toàn bộ kiểm tra hạn mức	API-2	SEC-02, FR-09	B-07.md (evidence/B-07.md)	<điền link>

C-01	● Critical	POST / PUT / DELETE /api/products hoàn toàn không xác thực	API-3	SEC-02, SEC-03, FR-12	C-01.md (evidence/C-01.md)	<điền link>
C-02	● Critical	SQL Injection qua tham số ?search=	API-3	SEC-05	C-02.md (evidence/C-02.md)	<điền link>
C-13	● Critical	Một sản phẩm có price = null làm SẬP HẦN backend khi đọc lại (tử chối dịch vụ)	API-3	FR-15	C-13.md (evidence/C-13.md)	<điền link>
X-01	● Critical	PUT /api/users/me cho phép user thường tự nâng role lên admin	liên API	SEC-06, FR-04, FR-12	X-01.md (evidence/X-01.md)	<điền link>
A-02	● High	OTP chỉ có 4 chữ số trong khi đặc tả đòi tối thiểu 6	API-1	SEC-07, FR-03	A-02.md (evidence/A-02.md)	<điền link>
A-03	● High	User enumeration qua mã trạng thái của forgot-password	API-1	FR-03	A-03.md (evidence/A-03.md)	<điền link>
A-05	● High	reset-password không kiểm tra độ mạnh mật khẩu	API-1	FR-01, FR-03	A-05.md (evidence/A-05.md)	<điền link>
A-09	● High	Bộ đếm đăng nhập sai cộng +2 mỗi lần nên tài khoản bị khóa ở lần sai thứ HAI	API-1	FR-02	A-09.md (evidence/A-09.md)	<điền link>
B-06	● High	Ngưỡng đơn tối thiểu dùng > thay vì >=	API-2	FR-09	B-06.md (evidence/B-06.md)	<điền link>
B-09	● High	PUT /api/orders/:id/cancel cho phép hủy đơn đang giao (shipping)	API-2	FR-10	B-09.md (evidence/B-09.md)	<điền link>
B-10	● High	admin/orders/:id/status cho phép chuyển canceled -> delivered	API-2	FR-10	B-10.md (evidence/B-10.md)	<điền link>
C-03	● High	Lỗi SQL trả về HTML kèm thông điệp của tầng CSDL	API-3	SEC-05	C-03.md (evidence/C-03.md)	<điền link>
C-04	● High	GET /api/products/:id với id không tồn tại trả 200 {} thay vì 404	API-3	FR-15	C-04.md (evidence/C-04.md)	<điền link>
C-05	● High	price là số với id lẻ nhưng là chuỗi với id chẵn	API-3	FR-15	C-05.md (evidence/C-05.md)	<điền link>
C-06	● High	POST /api/products không validate bất kỳ trường nào	API-3	FR-15	C-06.md (evidence/C-06.md)	<điền link>
A-08	● Medium	forgot-password bỏ qua biến lỗi của db.get nên lỗi CSDL bị báo thành 404	API-1	FR-03	A-08.md (evidence/A-08.md)	<điền link>

B-08	● Medium	Kiểm tra hạn sử dụng nằm bên trong nhánh ngưỡng đơn nên thông báo lỗi sai nguyên nhân	API-2	FR-09	B-08.md (evidence/B-08.md)	<điền link>
B-11	● Medium	POST /api/coupon-usage ghi nhận lượt dùng cho coupon_id không tồn tại	API-2	FR-09	B-11.md (evidence/B-11.md)	<điền link>
B-12	● Medium	checkout tạo được đơn hàng khi thiếu hân shipping_address	API-2	FR-08	B-12.md (evidence/B-12.md)	<điền link>
C-07	● Medium	PUT /api/products/:id với id không tồn tại vẫn trả 200 Product updated	API-3	FR-15	C-07.md (evidence/C-07.md)	<điền link>
C-08	● Medium	DELETE /api/products/:id với id không tồn tại vẫn trả 200 Product deleted	API-3	FR-15	C-08.md (evidence/C-08.md)	<điền link>
C-09	● Medium	PUT không hỗ trợ cập nhật một phần: trường không gửi bị ghi đè thành null	API-3	FR-15	C-09.md (evidence/C-09.md)	<điền link>
C-10	● Medium	category_id không được kiểm khóa ngoại	API-3	FR-15	C-10.md (evidence/C-10.md)	<điền link>
C-11	● Medium	name và description không được sanitize - nguồn của stored XSS	API-3	SEC-04	C-11.md (evidence/C-11.md)	<điền link>
B-14	○ Low	checkout trả về 200 thay vì 201 Created	API-2	FR-08	B-14.md (evidence/B-14.md)	<điền link>
C-12	○ Low	POST /api/products trả về 200 thay vì 201 Created	API-3	FR-15	C-12.md (evidence/C-12.md)	<điền link>

Tổng 34 bug: 12 Critical, 11 High, 9 Medium, 2 Low.

API	Số bug
API-1	7
API-2	13
API-3	13
liên API	1

Đề bài đòi tối thiểu 3 bug thật cho mỗi API; cả ba đều vượt xa ngưỡng này.

2. Chi tiết từng bug

A-01 — POST /api/forgot-password trả thẳng mã OTP trong response body

Mức độ	● Critical
--------	------------

API	API-1
Vi phạm	SEC-07, FR-03
Bằng chứng đầy đủ	bugs/evidence/A-01.md (evidence/A-01.md)

Ảnh hưởng: Bất kỳ ai biết địa chỉ email của nạn nhân đều chiếm được tài khoản trong hai request, không cần truy cập hộp thư. Đây là đường chiếm tài khoản ngắn nhất trong toàn hệ thống: gọi forgot-password để lấy OTP, rồi gọi reset-password để đặt mật khẩu mới.

Bước tái hiện (bước cuối của kịch bản; các bước chuẩn bị xem file bằng chứng):

```
curl -i -X POST 'http://localhost:3000/api/forgot-password' \
  -H 'Content-Type: application/json' \
  -H 'X-Student-ID: 03127060' \
  -d '{"email": "api-01@student-03127060test.local"}
```

Kết quả thực tế:

```
HTTP/1.1 200
Content-Type: application/json; charset=utf-8

{"message": "Mã đặt lại mật khẩu đã được tạo", "resetToken": "5656"}
```

Kết quả mong đợi: theo eshop-sut/README.md (SEC-07, FR-03).

Đề xuất sửa: Bỏ `resetToken` khỏi response. Gửi OTP qua email. Trong môi trường demo, ghi ra log máy chủ chứ không trả về cho client.

A-07 — Mật khẩu lưu plaintext và bị trả về trong response của `login / users/me`

Mức độ	● Critical
API	API-1
Vi phạm	SEC-01
Bằng chứng đầy đủ	bugs/evidence/A-07.md (evidence/A-07.md)

Ảnh hưởng: Cột `password` lưu nguyên văn. `SELECT *` rồi `res.json(user)` đưa cả `password` lẫn `reset_token` ra ngoài. Bất kỳ ai xem được một response login (log, proxy, cache trình duyệt) đều có mật khẩu thật. Vì người dùng thường dùng lại mật khẩu, thiệt hại vượt ra ngoài hệ thống này.

Bước tái hiện (bước cuối của kịch bản; các bước chuẩn bị xem file bằng chứng):

```
curl -i -X GET 'http://localhost:3000/api/users/me' \
  -H 'Content-Type: application/json' \
  -H 'X-Student-ID: 03127060' \
  -H 'Authorization: Bearer <token>'
```

Kết quả thực tế:

```
HTTP/1.1 200
Content-Type: application/json; charset=utf-8
```

Kết quả mong đợi: theo eshop-sut/README.md (SEC-01).

Đề xuất sửa: Băm mật khẩu bằng bcrypt khi ghi. Khi đọc, chọn đúng cột cần dùng thay vì SELECT *, hoặc loại bỏ password và reset_token trước khi trả về.

B-01 — checkout tin tuyệt đối total_amount do client gửi

Mức độ	● Critical
API	API-2
Vi phạm	FR-08
Bằng chứng đầy đủ	bugs/evidence/B-01.md (evidence/B-01.md)

Ảnh hưởng: SRS FR-08 ghi rõ: "Backend phải tự tính lại tổng tiền; không chấp nhận giá trị total_amount do client gửi lên". Thực tế giá trị được ghi thẳng vào bảng orders. Mua được điện thoại 30 triệu với giá 1 đồng. Đây là lỗ hổng gây thiệt hại tài chính trực tiếp.

Bước tái hiện (bước cuối của kịch bản; các bước chuẩn bị xem file bằng chứng):

```
curl -i -X GET 'http://localhost:3000/api/orders/3' \
-H 'Content-Type: application/json' \
-H 'X-Student-Id: 03127080' \
-H 'Authorization: Bearer <token>'
```

Kết quả thực tế:

```
HTTP/1.1 200
Content-Type: application/json; charset=utf-8

{"id":3,"user_id":3,"total_amount":1,"status":"pending","shipping_address":{"id":1,"created_at":"2025-09-01T08:33:32"}}
```

Kết quả mong đợi: theo eshop-sut/README.md (FR-08).

Đề xuất sửa: Bỏ total_amount khỏi body. Tính lại từ giỏ hàng phía máy chủ: đọc userCarts[userId], tra cứu giá từng sản phẩm trong bảng products, rồi cộng lại.

B-01b — checkout chấp nhận total_amount âm

Mức độ	● Critical
API	API-2
Vi phạm	FR-08
Bằng chứng đầy đủ	bugs/evidence/B-01b.md (evidence/B-01b.md)

Ảnh hưởng: Trường hợp riêng của B-01 nhưng đáng chú ý riêng: đơn hàng có tổng tiền âm được tạo thành công. Nếu hệ thống có bước hoàn tiền hoặc tính doanh thu, số âm sẽ làm sai toàn bộ sổ sách.

Bước tái hiện (bước cuối của kịch bản; các bước chuẩn bị xem file bằng chứng):

```
curl -i -X POST 'http://localhost:3000/api/checkout' \
  -H 'Content-Type: application/json' \
  -H 'x-student-id: 23127000' \
  -H 'Authorization: Bearer <token>' \
  -d '{"total_amount": 500000, "shipping_address": "1 Le Loi"'
```

Kết quả thực tế:

```
HTTP/1.1 200
Content-Type: application/json; charset=utf-8

{"message": "Checkout successful", "orderId": 11}
```

Kết quả mong đợi: theo eshop-sut/README.md (FR-08).

Đề xuất sửa: Sau khi tự tính lại tổng tiền phía máy chủ, thêm ràng buộc CHECK (total_amount > 0) ở tầng CSDL.

B-02 — GET /api/orders/:id thiếu hạn xác thực - IDOR

Mức độ	Critical
API	API-2
Vi phạm	SEC-02
Bằng chứng đầy đủ	bugs/evidence/B-02.md (evidence/B-02.md)

Ảnh hưởng: Endpoint không có middleware authenticateToken. Bất kỳ ai duyệt lần lượt id từ 1 đều đọc được toàn bộ đơn hàng của mọi người dùng: địa chỉ giao hàng, tổng tiền, trạng thái. Đây là lộ lọt dữ liệu cá nhân trên diện rộng.

Bước tái hiện (bước cuối của kịch bản; các bước chuẩn bị xem file bằng chứng):

```
curl -i -X GET 'http://localhost:3000/api/orders/11' \
  -H 'Content-Type: application/json' \
  -H 'x-student-id: 23127000'
```

Kết quả thực tế:

```
HTTP/1.1 200
Content-Type: application/json; charset=utf-8

{"id": 11, "user_id": 11, "total_amount": 500000, "status": "pending", "shipping_address": "1 Le Loi", "created_at": "2023-09-01 09:33:00"}
```

Kết quả mong đợi: theo eshop-sut/README.md (SEC-02).

Đề xuất sửa: Thêm authenticateToken vào endpoint, và thêm điều kiện AND user_id = ? vào câu truy vấn để người dùng chỉ đọc được đơn của chính mình.

B-03 — PUT /api/admin/orders/:id/status không kiểm tra role

Mức độ	● Critical
API	API-2
Vi phạm	SEC-03, FR-12
Bằng chứng đầy đủ	bugs/evidence/B-03.md (evidence/B-03.md)

Ảnh hưởng: Endpoint có `authenticateToken` nhưng không hề đọc `req.user.role`. Bất kỳ người dùng đăng nhập nào cũng đổi được trạng thái đơn hàng của người khác - ví dụ đánh dấu đơn của người khác là đã giao để chặn việc hủy đơn.

Bước tái hiện (bước cuối của kịch bản; các bước chuẩn bị xem file bằng chứng):

```
curl -i -X PUT 'http://localhost:3000/api/admin/orders/12/status' \
  -H 'Content-Type: application/json' \
  -H 'X-Student-Id: 23127060' \
  -H 'Authorization: Bearer <token>' \
  -d '{"status": "Completed"}
```

Kết quả thực tế:

```
HTTP/1.1 200
Content-Type: application/json; charset=utf-8

{"message": "Order status updated"}
```

Kết quả mong đợi: theo `eshop-sut/README.md` (SEC-03, FR-12).

Đề xuất sửa: Thêm middleware kiểm quyền: `if (req.user.role !== 'admin') return res.status(403).json(...)`. Áp cho toàn bộ nhóm đường dẫn `/api/admin/*`.

B-05 — Công thức giảm giá percent sai dấu, cho ra số tiền giảm ÂM

Mức độ	● Critical
API	API-2
Vi phạm	FR-09
Bằng chứng đầy đủ	bugs/evidence/B-05.md (evidence/B-05.md)

Ảnh hưởng: Code tính `discount = Math.floor(total * (1 - discount_value))`. Với `discount_value = 10` (nghĩa là 10%), công thức thành `total * (1 - 10) = total * (-9)`. Với đơn 500.000đ, `discount_amount` là -4.500.000 và `final_amount` thành 5.000.000 - khách hàng bị tính gấp mười lần khi áp mã giảm giá. SRS FR-09 ghi rõ công thức đúng là `total * discount_value / 100`.

Bước tái hiện (bước cuối của kịch bản; các bước chuẩn bị xem file bằng chứng):

```
curl -i -X POST 'http://localhost:3000/api/apply-coupon' \
  -H 'Content-Type: application/json' \
  -H 'X-Student-Id: 23127060' \
  -d '{"code": "SAVE10", "total_amount": 500000, "user_id": 1}'
```

Kết quả thực tế:

```
HTTP/1.1 200
Content-Type: application/json; charset=utf-8

{"success":true,"coupon_id":1,"discount_amount":150000,"final_amount":2000000,"message":"\u00c1p d\u00fang h\u00e0nh c\u00f3n\u00e2m 5.0\u00c2m 10%"}

```

Kết quả mong đợi: theo eshop-sut/README.md (FR-09).

Đề xuất sửa: Sửa thành `Math.floor(total_amount * coupon.discount_value / 100)`.

B-07 — apply-coupon không xác thực; bỏ user_id là bỏ qua toàn bộ kiểm tra hạn mức

Mức độ	● Critical
API	API-2
Vi phạm	SEC-02, FR-09
Bằng chứng đầy đủ	bugs/evidence/B-07.md (evidence/B-07.md)

Ảnh hưởng: Endpoint không có `authenticateToken` và lấy `user_id` từ body. Nghiêm trọng hơn: phép kiểm hạn mức nằm trong nhánh `if (user_id)`, nên không gửi trường này sẽ đi vào nhánh `else` và áp mã mà không đếm lượt nào cả. Đây là nghịch lý "bỏ bớt dữ liệu để được nhiều quyền hơn": mã giới hạn một lượt mỗi người trở thành dùng được vô hạn.

Bước tái hiện (bước cuối của kịch bản; các bước chuẩn bị xem file bằng chứng):

```
curl -i -X POST 'http://localhost:3000/api/apply-coupon' \
-H 'Content-Type: application/json' \
-d '{ "user_id": "3123456" \
  "code": "VF100", "total_amount": 300000 }'

```

Kết quả thực tế:

```
HTTP/1.1 200
Content-Type: application/json; charset=utf-8

{"success":true,"coupon_id":3,"discount_amount":100000,"final_amount":1400000,"message":"\u00c1p d\u00fang h\u00e0nh c\u00f3n\u00e2m 5.0\u00c2m 100,000 d"}

```

Kết quả mong đợi: theo eshop-sut/README.md (SEC-02, FR-09).

Đề xuất sửa: Thêm `authenticateToken` và lấy `user_id` từ `req.user.id`, không bao giờ từ body. Bỏ hoàn toàn nhánh `else`.

C-01 — POST / PUT / DELETE /api/products hoàn toàn không xác thực

Mức độ	● Critical
API	API-3

Vi phạm	SEC-02, SEC-03, FR-12
Bằng chứng đầy đủ	bugs/evidence/C-01.md (evidence/C-01.md)

Ảnh hưởng: SRS FR-12 liệt kê đích danh ba endpoint này trong nhóm bắt buộc phải có token JWT hợp lệ và role = 'admin'. Thực tế không có middleware nào cả. Một người hoàn toàn không đăng nhập có thể xóa sạch toàn bộ catalog sản phẩm, hoặc sửa giá mọi mặt hàng về 0. Đây là bug nghiêm trọng nhất của API-3.

Bước tái hiện (bước cuối của kịch bản; các bước chuẩn bị xem file bằng chứng):

```
curl -i -X DELETE 'http://localhost:3000/api/products/14' \
-H 'Content-Type: application/json' \
-H 'X-Student-Id: 33129080'
```

Kết quả thực tế:

```
HTTP/1.1 201
Content-Type: application/json; charset=utf-8

{"message":"Product deleted"}
```

Kết quả mong đợi: theo eshop-sut/README.md (SEC-02, SEC-03, FR-12).

Đề xuất sửa: Thêm authenticateToken và middleware kiểm tra role === 'admin' cho cả ba endpoint.

C-02 — SQL Injection qua tham số ?search=

Mức độ	🔴 Critical
API	API-3
Vi phạm	SEC-05
Bằng chứng đầy đủ	bugs/evidence/C-02.md (evidence/C-02.md)

Ảnh hưởng: Câu truy vấn được nối chuỗi trực tiếp: WHERE name LIKE '%\${searchQuery}%'. Payload '%' OR '1'='1 trả về toàn bộ bảng. Nghiêm trọng hơn, payload UNION SELECT đọc được bảng users: lần chạy thử nghiệm trả về nguyên văn admin@eshop.com kèm mật khẩu Admin123! trong trường price. Kết hợp với A-07 (mật khẩu lưu plaintext), một request duy nhất lấy được thông tin đăng nhập của quản trị viên.

Bước tái hiện (bước cuối của kịch bản; các bước chuẩn bị xem file bằng chứng):

```
curl -i -X GET 'http://localhost:3000/api/products?search=%25%27%20UNION%20SELECT%20id%2Cemail%2Cpassword%2Crole%2C1%2C1%20FROM%20users--%20' \
-H 'Content-Type: application/json' \
-H 'X-Student-Id: 33129080'
```

Kết quả thực tế:

```
HTTP/1.1 200
Content-Type: application/json; charset=utf-8

[{"id":1,"name":"admin@eshop.com","price":"Admin123!","description":"admin","imageUrl":1,"category_id":1,
```

```
["id":1,"name":"iPhone 15 Pro Max","price":30000000,"description":"Điện thoại cao cấp của Apple","imageUrl":"https://placeholder.co/300x300/png?text=iPhone+15","category_id":1},
{"id":2,"name":"Samsung Galaxy S24 Ultra","price":28000000,"description":"Màn hình hiển thị xuất sắc, camera siêu zoom","imageUrl":"https://placeholder.co/300x300/png?text=Samsung+S24","category_id":1},
{"id":3,"name":"Macbook Pro M1","price":15000000,"description":"Laptop chuyên nghiệp nhất hiện nay","imageUrl":"https://placeholder.co/300x300/png?text=Macbook+Pro","category_id":2},
{"id":3,"name":"api.a01.victim.23127060@test.local","price":"Api1234!","description":"user","imageUrl":1},
{"id":4,"name":"Tai nghe AirPods Pro 2","price":16000000,"description":"Chống ồn chủ động xuất sắc","imageUrl":"https://placeholder.co/300x300/png?text=AirPods+Pro","category_id":3},
{"id":3,"name":"api.a01.victim.23127060@test.local","price":"Api1234!","description":"user","imageUrl":1},
{"id":5,"name":"Bàn",".. (đã cắt bớt)
```

Kết quả mong đợi: theo eshop-sut/README.md (SEC-05).

Đề xuất sửa: Dùng tham số hóa: `db.all("SELECT * FROM products WHERE name LIKE ?", ['%' + searchQuery + '%'], ...)`. Đây đúng là điều SEC-05 yêu cầu.

C-13 — Một sản phẩm có `price = null` làm SẬP HẸN backend khi đọc lại (từ chối dịch vụ)

Mức độ	🔴 Critical
API	API-3
Vi phạm	FR-15
Bằng chứng đầy đủ	bugs/evidence/C-13.md (evidence/C-13.md)

Ảnh hưởng: Đây là bug nguy hiểm nhất em tìm được, và nó là **hệ quả dây chuyền của hai bug khác**. C-09 cho phép một lệnh `PUT` thiếu trường ghi đè `price` thành `null`. Sau đó, C-05 chạy `row.price.toString()` trên giá trị `null` khi id là số chẵn. `TypeError` ném ra trong callback của `sqlite3` không được ai bắt, Node thoát hẳn, **toàn bộ API ngưng phục vụ**. Trong lần chạy thử nghiệm, request tiếp theo trả về `Connection refused` và mọi kịch bản sau đó không chạy được nữa. Một người không đăng nhập có thể hạ gục toàn bộ hệ thống bằng hai request (C-01 cho phép gọi `PUT` mà không cần token). Không bug nào trong ba bug thành phần tự nó gây sập; chỉ tổ hợp của chúng mới gây.

Bước tái hiện (bước cuối của kịch bản; các bước chuẩn bị xem file bằng chứng):

```
curl -X PUT -H 'Content-Type: application/json' -d '{"id":2,"name":"Macbook Pro M1","price":15000000,"description":"Laptop chuyên nghiệp nhất hiện nay","imageUrl":"https://placeholder.co/300x300/png?text=Macbook+Pro","category_id":2}' http://localhost:3000/api/products
```

Kết quả thực tế:

```
HTTP/1.1 0
Content-Type: (không có)

Uncaught Error: [Error: 11] Connection refused
```

Kết quả mong đợi: theo eshop-sut/README.md (FR-15).

Đề xuất sửa: Sửa cả ba: (1) C-01 thêm xác thực; (2) C-09 chỉ cập nhật trường được gửi; (3) C-05 xóa dòng ép kiểu. Ngoài ra bắt buộc phải có `process.on('uncaughtException')` và một tầng xử lý lỗi cho mọi callback của tầng CSDL, để một bản ghi hỏng không thể hạ được cả tiến trình.

X-01 — PUT /api/users/me cho phép user thường tự nâng role lên admin

Mức độ	Critical
API	liên API
Vi phạm	SEC-06, FR-04, FR-12
Bằng chứng đầy đủ	bugs/evidence/X-01.md (evidence/X-01.md)

Ảnh hưởng: Endpoint nhận trường `role` từ body và ghi thẳng vào CSDL. Bất kỳ tài khoản nào cũng tự trở thành admin bằng một request. Kết hợp với việc các API admin khác chỉ kiểm sự tồn tại của token, đây là đường leo thang quyền trọn vẹn.

Bước tái hiện (bước cuối của kịch bản; các bước chuẩn bị xem file bằng chứng):

```
curl -i -X GET 'http://localhost:3000/api/users/me' \
-H 'Content-Type: application/json' \
-H 'X-Student-Id: 23127060' \
-H 'Authorization: Bearer token'
```

Kết quả thực tế:

```
HTTP/1.1 200
Content-Type: application/json; charset=utf-8

{"id":3,"name":"attacker","email":"api.x01.attacker.23127060@test.local","password":"api2312","role":"a"}
```

Kết quả mong đợi: theo eshop-sut/README.md (SEC-06, FR-04, FR-12).

Đề xuất sửa: Bỏ `role` khỏi danh sách trường được phép cập nhật. Chỉ cho phép đúng ba trường `name`, `phone`, `shipping_address` như SRS FR-04 quy định.

A-02 — OTP chỉ có 4 chữ số trong khi đặc tả đòi tối thiểu 6

Mức độ	High
API	API-1
Vi phạm	SEC-07, FR-03
Bằng chứng đầy đủ	bugs/evidence/A-02.md (evidence/A-02.md)

Ảnh hưởng: Không gian mã chỉ 9000 giá trị (1000-9999). Không có giới hạn số lần thử nên dò hết toàn bộ không gian là khả thi. Nghiêm trọng hơn: với 4 chữ số, chỉ cần khoảng 100 người cùng đang chờ reset là xác suất có hai người trùng mã vượt 40% (nghịch lý ngày sinh) - khi đó điều kiện `email AND reset_token` không còn bảo vệ được ai.

Bước tái hiện (bước cuối của kịch bản; các bước chuẩn bị xem file bằng chứng):

```
curl -i -X POST 'http://localhost:3000/api/forget-password' \
-H 'Content-Type: application/json' \
-H 'X-Student-Id: 23127060' \
-d '{"email": "api.a02.victim.23127060@test.local"}'
```

Kết quả thực tế:

```
HTTP/1.1 200
Content-Type: application/json; charset=utf-8

{"message": "Mật đặt lại mật khẩu đã được gửi", "resetToken": "2209"}
```

Kết quả mong đợi: theo eshop-sut/README.md (SEC-07, FR-03).

Đề xuất sửa: `Math.floor(100000 + Math.random() * 900000)` cho 6 chữ số, và tốt hơn là dùng `crypto.randomInt` thay vì `Math.random` (không an toàn về mặt mật mã).

A-03 — User enumeration qua mã trạng thái của forgot-password

Mức độ	● High
API	API-1
Vi phạm	FR-03
Bằng chứng đầy đủ	bugs/evidence/A-03.md (evidence/A-03.md)

Ảnh hưởng: Email không tồn tại trả 404, email tồn tại trả 200. Kẻ tấn công dò được toàn bộ danh sách người dùng của hệ thống chỉ bằng cách thử lần lượt các địa chỉ email.

Bước tái hiện (bước cuối của kịch bản; các bước chuẩn bị xem file bằng chứng):

```
curl -X POST 'http://localhost:3000/api/forgot-password' \
-H 'Content-Type: application/json' \
-H 'X-Student-Id: 23127060' \
-d '{"email": "khongtontai.23127060@test.local"}'
```

Kết quả thực tế:

```
HTTP/1.1 404
Content-Type: application/json; charset=utf-8

{"error": "User not found"}
```

Kết quả mong đợi: theo eshop-sut/README.md (FR-03).

Đề xuất sửa: Luôn trả về 200 với cùng một thông điệp chung chung, bất kể email có tồn tại hay không.

A-05 — reset-password không kiểm tra độ mạnh mật khẩu

Mức độ	● High
API	API-1
Vi phạm	FR-01, FR-03
Bằng chứng đầy đủ	bugs/evidence/A-05.md (evidence/A-05.md)

Đề xuất sửa: Đổi + 2 thành + 1 và 180000 thành 30000.

B-06 — Ngưỡng đơn tối thiểu dùng > thay vì >=

Mức độ	● High
API	API-2
Vi phạm	FR-09
Bằng chứng đầy đủ	bugs/evidence/B-06.md (evidence/B-06.md)

Ảnh hưởng: SRS FR-09 điều kiện C3 ghi rõ "Tổng đơn hàng >= (lớn hơn hoặc bằng) min_order_amount". Code viết if (total_amount > coupon.min_order_amount). Đơn có giá trị bằng đúng ngưỡng bị từ chối. Đây là lỗi biên kinh điển, và nó rơi đúng vào trường hợp người dùng hay gặp nhất: mua vừa đủ ngưỡng để được giảm giá.

Bước tái hiện (bước cuối của kịch bản; các bước chuẩn bị xem file bằng chứng):

```
curl -X POST -H "Host: localhost:3000" -d '{"coupon_id": 1, "content_type": "application/json", "student_id": 23127060, "code": "SAVE10", "total_amount": 300001, "user_id": 1}'
```

Kết quả thực tế:

```
HTTP/1.1 200
Content-Type: application/json; charset=utf-8
{"success": true, "coupon_id": 1, "discount_amount": -2700009, "final_amount": 3000010, "message": "Áp dụng thành công! Giảm 10%!"}
```

Kết quả mong đợi: theo eshop-sut/README.md (FR-09).

Đề xuất sửa: Đổi > thành >=.

B-09 — PUT /api/orders/:id/cancel cho phép hủy đơn đang giao (shipping)

Mức độ	● High
API	API-2
Vi phạm	FR-10
Bằng chứng đầy đủ	bugs/evidence/B-09.md (evidence/B-09.md)

Ảnh hưởng: SRS FR-10 ghi rõ: "Khi đơn hàng đã ở trạng thái shipping, User không được phép tự hủy - chỉ Admin mới có thể thao tác". Code chỉ chặn delivered và canceled. Khách hàng hủy đơn khi hàng đang trên đường giao, gây thất thoát hàng và chi phí vận chuyển. Chính comment trong mã nguồn cũng thừa nhận điều kiện này sai.

Bước tái hiện (bước cuối của kịch bản; các bước chuẩn bị xem file bằng chứng):

```
curl -i -X GET 'http://localhost:3000/api/orders/13' \
-H 'Content-Type: application/json' \
-H 'X-Student-Id: 23127060'
```

Kết quả thực tế:

```
HTTP/1.1 200
Content-Type: application/json; charset=utf-8

{"id":13,"user_id":15,"total_amount":1500000,"status":"canceled","shipping_address":"1 Le
 Loi","created_at":"2026-03-01 06:33:13"}
```

Kết quả mong đợi: theo eshop-sut/README.md (FR-10).

Đề xuất sửa: Đổi điều kiện thành `if (order.status !== 'pending' && order.status !== 'confirmed')` đúng như comment trong mã nguồn đã ghi.

B-10 — `admin/orders/:id/status` cho phép chuyển `canceled -> delivered`

Mức độ	● High
API	API-2
V phạm	FR-10
Bằng chứng đầy đủ	bugs/evidence/B-10.md (evidence/B-10.md)

Ảnh hưởng: SRS FR-10 ghi rõ `delivered` và `canceled` là trạng thái kết thúc, không được chuyển sang bất kỳ trạng thái nào khác. Trong mã nguồn có một dòng riêng biệt `if (currentStatus === 'canceled' && status === 'delivered') isValidTransition = true` - một đơn đã hủy có thể bị đánh dấu là đã giao.

Bước tái hiện (bước cuối của kịch bản; các bước chuẩn bị xem file bằng chứng):

```
curl -i -X GET 'http://localhost:3000/api/orders/14' \
-H 'Content-Type: application/json' \
-H 'X-Student-Id: 23127060'
```

Kết quả thực tế:

```
HTTP/1.1 200
Content-Type: application/json; charset=utf-8

{"id":14,"user_id":15,"total_amount":1500000,"status":"delivered","shipping_address":"1 Le
 Loi","created_at":"2026-03-01 06:33:13"}
```

Kết quả mong đợi: theo eshop-sut/README.md (FR-10).

Đề xuất sửa: Xóa dòng đó. Tốt hơn: thay chuỗi `if` bằng một bảng chuyển trạng thái khai báo được, để sơ đồ FR-10 và mã nguồn đọc ra cùng một thứ.

C-03 — Lỗi SQL trả về HTML kèm thông điệp của tầng CSDL

Mức độ	● High
API	API-3
Vi phạm	SEC-05
Bằng chứng đầy đủ	bugs/evidence/C-03.md (evidence/C-03.md)

Ảnh hưởng: Khi truy vấn lỗi, máy chủ trả `res.status(500).send('<h1>Database Error</h1><p>' + err.message + '</p>')` với `Content-Type: text/html`. Hai hậu quả: lộ cấu trúc CSDL cho kẻ tấn công (giúp tinh chỉnh payload SQLi), và phá vỡ hợp đồng JSON khiến client gọi `response.json()` bị ném lỗi.

Bước tái hiện (bước cuối của kịch bản; các bước chuẩn bị xem file bằng chứng):

```
curl -i -X GET 'http://localhost:3000/api/products?error=314' \
-H 'Content-Type: application/json' \
-H 'X-Student-Id: 23127060'
```

Kết quả thực tế:

```
HTTP/1.1 500
Content-Type: text/html; charset=utf-8

<h1>Database Error</h1><p>SQLITE_ERROR: unrecognized token: "314"</p>
```

Kết quả mong đợi: theo `eshop-sut/README.md` (SEC-05)

Đề xuất sửa: Trả về `res.status(500).json({ error: 'Internal server error' })`. Ghi `err.message` vào log máy chủ, không gửi cho client.

C-04 — GET /api/products/:id với id không tồn tại trả 200 {} thay vì 404

Mức độ	● High
API	API-3
Vi phạm	FR-15
Bằng chứng đầy đủ	bugs/evidence/C-04.md (evidence/C-04.md)

Ảnh hưởng: Dòng `if (!row) return res.status(200).json({})` trả về thành công cho một tài nguyên không tồn tại. Client không phân biệt được "không tìm thấy" với "tìm thấy nhưng rỗng", và lớp hiển thị sẽ vẽ ra một sản phẩm trống thay vì báo lỗi.

Bước tái hiện (bước cuối của kịch bản; các bước chuẩn bị xem file bằng chứng):

```
curl -i -X GET 'http://localhost:3000/api/products/999999' \
-H 'Content-Type: application/json' \
-H 'X-Student-Id: 23127060'
```

Kết quả thực tế:

```
HTTP/1.1 200
Content-Type: application/json; charset=utf-8
```

Kết quả mong đợi: theo eshop-sut/README.md (FR-15).

Đề xuất sửa: return res.status(404).json({ error: 'Product not found' }).

C-05 — price là số với id lẻ nhưng là chuỗi với id chẵn

Mức độ	● High
API	API-3
Vi phạm	FR-15
Bằng chứng đầy đủ	bugs/evidence/C-05.md (evidence/C-05.md)

Ảnh hưởng: Dòng if (row.id % 2 === 0) row.price = row.price.toString() đổi kiểu dữ liệu theo tính chẵn lẻ của khóa chính. Client cộng tiền sẽ nhận "28000000" + 1000 ra chuỗi "280000001000". Bug chỉ lộ ra khi so sánh hai response với nhau; test riêng từng response đều thấy hợp lệ.

Bước tái hiện (bước cuối của kịch bản, các bước chuẩn bị xem file bằng chứng).

```
url="http://localhost:3000/api/products/2"
-B 'Content-Type: application/json'
-B 'X-Student-Id: 23127060'
```

Kết quả thực tế:

```
HTTP/1.1 200
Content-Type: application/json; charset=utf-8

{"id":2,"name":"Samsung Galaxy S24 Ultra","price":"28000000","description":"Màn hình hiển thị xuất sắc, camera siêu zoom","imageUrl":"https://placeholder.co/300x300/png?text=samsung+s24","category_id":1}
```

Kết quả mong đợi: theo eshop-sut/README.md (FR-15).

Đề xuất sửa: Xóa dòng đó. Thêm ràng buộc kiểu vào hợp đồng API và kiểm bằng JSON Schema trong bộ test hồi quy.

C-06 — POST /api/products không validate bất kỳ trường nào

Mức độ	● High
API	API-3
Vi phạm	FR-15
Bằng chứng đầy đủ	bugs/evidence/C-06.md (evidence/C-06.md)

Ảnh hưởng: SRS FR-15 đòi: tên bắt buộc tối đa 255 ký tự, giá bắt buộc và phải dương, danh mục bắt buộc chọn từ danh sách có sẵn. Thực tế tạo được sản phẩm với price: -100, price: "abc", name: null. Dữ liệu hỏng đi vào CSDL và gây hậu quả dây chuyền - xem C-13.

Bước tái hiện (bước cuối của kịch bản; các bước chuẩn bị xem file bằng chứng):

```
curl -i -X POST 'http://localhost:3000/api/products' \
  -H 'Content-Type: application/json' \
  -H 'X-Student-Id: 23127060' \
  -d '{"name": null, "price": "app", "description": "x", "imageId": "", "categoryId": 1}'
```

Kết quả thực tế:

```
HTTP/1.1 201
Content-Type: application/json; charset=utf-8

{"message": "Product created", "id": 1}
```

Kết quả mong đợi: theo eshop-sut/README.md (FR-15).

Đề xuất sửa: Thêm tầng validate đầu vào (ví dụ express-validator hoặc một hàm kiểm tay) trước khi ghi.

A-08 — forgot-password bỏ qua biến lỗi của db.get nên lỗi CSDL bị báo thành 404

Mức độ	● Medium
API	API-1
Vi phạm	FR-03
Bằng chứng đầy đủ	bugs/evidence/A-08.md (evidence/A-08.md)

Ảnh hưởng: Callback nhận (err, user) nhưng chỉ kiểm if (!user). Mọi sự cố tầng CSDL đều biến thành "User not found", che mất sự cố thật và làm người dùng tưởng tài khoản của họ không tồn tại.

Bước tái hiện (bước cuối của kịch bản; các bước chuẩn bị xem file bằng chứng):

```
curl -i -X POST 'http://localhost:3000/api/forgot-password' \
  -H 'Content-Type: application/json' \
  -H 'X-Student-Id: 23127060' \
  -d '{"email": null}'
```

Kết quả thực tế:

```
HTTP/1.1 404
Content-Type: application/json; charset=utf-8

{"error": "User not found"}
```

Kết quả mong đợi: theo eshop-sut/README.md (FR-03).

Đề xuất sửa: Kiểm if (err) return res.status(500).json({ error: 'Internal error' }) trước khi kiểm ! user.

B-08 — Kiểm tra hạn sử dụng nằm bên trong nhánh ngưỡng đơn nên thông báo lỗi sai nguyên nhân

Mức độ	● Medium
API	API-2
Vi phạm	FR-09
Bằng chứng đầy đủ	bugs/evidence/B-08.md (evidence/B-08.md)

Ảnh hưởng: Phép kiểm `expired_at` được lồng bên trong `if (total_amount > min_order_amount)`. Một mã đã hết hạn dùng cho đơn nhỏ hơn ngưỡng sẽ báo "chưa đủ giá trị tối thiểu" thay vì "mã đã hết hạn". Người dùng sẽ cố mua thêm hàng để đạt ngưỡng rồi vẫn bị từ chối.

Bước tái hiện (bước cuối của kịch bản; các bước chuẩn bị xem file bằng chứng):

```
curl -i -X POST 'http://localhost:3000/api/apply-coupon' \
  -H 'Content-Type: application/json' \
  -H 'X-Student-Id: 23127000' \
  -d '{"code": "EXPIRED", "total_amount": 50000, "user_id": 1}'
```

Kết quả thực tế:

```
HTTP/1.1 200
Content-Type: application/json; charset=utf-8

{"error": "Đơn hàng chưa đủ giá trị tối thiểu 100,000 đ để áp dụng mã này"}
```

Kết quả mong đợi: theo `eshop-sut/README.md` (FR-09).

Đề xuất sửa: Tách năm điều kiện C1-C5 của FR-09 thành năm phép kiểm độc lập, chạy theo đúng thứ tự ưu tiên và mỗi phép kiểm trả về thông báo riêng.

B-11 — `POST /api/coupon-usage` ghi nhận lượt dùng cho `coupon_id` không tồn tại

Mức độ	● Medium
API	API-2
Vi phạm	FR-09
Bằng chứng đầy đủ	bugs/evidence/B-11.md (evidence/B-11.md)

Ảnh hưởng: Không kiểm tra mã giảm giá có tồn tại không, cũng không gắn với đơn hàng nào. Kẻ tấn công tạo được bản ghi rác, hoặc chen lượt dùng giả cho tài khoản người khác để họ không dùng được mã nữa.

Bước tái hiện (bước cuối của kịch bản; các bước chuẩn bị xem file bằng chứng):

```
curl -i -X POST 'http://localhost:3000/api/coupon-usage' \
  -H 'Content-Type: application/json' \
  -H 'X-Student-Id: 23127000' \
  -H 'Authorization: Bearer <token>' \
  -d '{"coupon_id": 999999}'
```

Kết quả thực tế:

```
HTTP/1.1 200
```

```
Content-Type: application/json; charset=utf-8
```

```
{"message": "Usage recorded"}
```

Kết quả mong đợi: theo eshop-sut/README.md (FR-09).

Đề xuất sửa: Kiểm tra `coupon_id` tồn tại và gắn bản ghi với `order_id` thật. Tốt nhất là ghi nhận lượt dùng ngay trong giao dịch thanh toán thay vì để client gọi một endpoint riêng.

B-12 — checkout tạo được đơn hàng khi thiếu hẳn `shipping_address`

Mức độ	● Medium
API	API-2
Vi phạm	FR-08
Bằng chứng đầy đủ	bugs/evidence/B-12.md (evidence/B-12.md)

Ảnh hưởng: Không có phép kiểm nào. Đơn hàng được tạo với địa chỉ giao hàng `null`, không thể giao được và chỉ phát hiện ra ở khâu vận hành.

Bước tái hiện (bước cuối của kịch bản; các bước chuẩn bị xem file bằng chứng):

```
curl -i -X GET 'http://localhost:3000/api/orders/15'
Content-Type: application/json
{"id":15,"user_id":1,"total_amount":100,"status":"pending","shipping_address":null,"created_at":"2020-01-01T00:00:00"}
```

Kết quả thực tế:

```
HTTP/1.1 200
Content-Type: application/json; charset=utf-8

{"id":15,"user_id":1,"total_amount":100,"status":"pending","shipping_address":null,"created_at":"2020-01-01T00:00:00"}
```

Kết quả mong đợi: theo eshop-sut/README.md (FR-08).

Đề xuất sửa: Kiểm tra `shipping_address` bắt buộc và không rỗng trước khi ghi; hoặc lấy địa chỉ mặc định từ hồ sơ người dùng khi client không gửi.

C-07 — PUT /api/products/:id với id không tồn tại vẫn trả 200 Product updated

Mức độ	● Medium
API	API-3
Vi phạm	FR-15
Bằng chứng đầy đủ	bugs/evidence/C-07.md (evidence/C-07.md)

Ảnh hưởng: Callback không đọc `this.changes`, nên không phân biệt được "đã cập nhật 1 dòng" với "không dòng nào khớp". Client tưởng đã lưu thành công trong khi không có gì thay đổi.

Bước tái hiện (bước cuối của kịch bản; các bước chuẩn bị xem file bằng chứng):

```
curl -i -X PUT 'http://localhost:3000/api/products/999999'
-H 'Content-Type: application/json' \
-H 'X-Student-id: 23127060' \
-d '{"name": "Không tồn tại", "price": 1, "description": "x", "imageUrl": "", "category": ""}'
```

Kết quả thực tế:

```
HTTP/1.1 200
Content-Type: application/json; charset=utf-8

{"message": "Product updated"}
```

Kết quả mong đợi: theo eshop-sut/README.md (FR-15).

Đề xuất sửa: if (this.changes === 0) return res.status(404).json({ error: 'Product not found' }).

C-08 — DELETE /api/products/:id với id không tồn tại vẫn trả 200 Product deleted	
Mức độ	● Medium
API	API-3
Vi phạm	FR-15
Bằng chứng đầy đủ	bugs/evidence/C-08.md (evidence/C-08.md)

Ảnh hưởng: Cùng nguyên nhân với C-07.

Bước tái hiện (bước cuối của kịch bản; các bước chuẩn bị xem file bằng chứng):

```
curl -i -X DELETE 'http://localhost:3000/api/products/999999'
-H 'Content-Type: application/json' \
-H 'X-Student-id: 23127060'
```

Kết quả thực tế:

```
HTTP/1.1 200
Content-Type: application/json; charset=utf-8

{"message": "Product deleted"}
```

Kết quả mong đợi: theo eshop-sut/README.md (FR-15).

Đề xuất sửa: Kiểm tra this.changes trước khi trả về thành công.

C-09 — PUT không hỗ trợ cập nhật một phần: trường không gửi bị ghi đè thành null	
Mức độ	● Medium
API	API-3

Vi phạm	FR-15
Bằng chứng đầy đủ	bugs/evidence/C-09.md (evidence/C-09.md)
Ảnh hưởng: Câu UPDATE products SET name=?, price=?, description=?, imageUrl=?, category_id=? luôn ghi cả năm cột. Gửi một body chỉ có <u>name</u> sẽ xóa trắng bốn trường còn lại. Lần chạy thử nghiệm cho kết quả {"price": null, "description": null, "imageUrl": null, "category_id": null}. Đây là nguyên nhân trực tiếp của C-13.	
Bước tái hiện (bước cuối của kịch bản; các bước chuẩn bị xem file bằng chứng):	
<pre>curl -i -X GET 'http://localhost:3000/api/products/17' -H 'Content-Type: application/json' -H 'X-Student-Id: 23127060'</pre>	
Kết quả thực tế:	
<pre>HTTP/1.1 200 Content-Type: application/json; charset=utf-8 {"id":17,"name":"","price":null,"description":null,"imageUrl":null,"category_id":null}</pre>	
Kết quả mong đợi: theo eshop-sut/README.md (FR-15).	
Đề xuất sửa: Dựng câu UPDATE động chỉ gồm các trường thật sự có mặt trong body, hoặc đòi hỏi PUT phải gửi đủ và dùng PATCH cho cập nhật một phần.	
C-10 — <u>category_id</u> không được kiểm khóa ngoại	
Mức độ	🟡 Medium
API	API-3
Vi phạm	FR-15
Bằng chứng đầy đủ	bugs/evidence/C-10.md (evidence/C-10.md)
Ảnh hưởng: Tạo được sản phẩm với category_id = 9999 trong khi bảng categories chỉ có id 1, 2, 3. Sản phẩm trở tới một danh mục không tồn tại và sẽ không hiện ra ở bất kỳ bộ lọc theo danh mục nào.	
Bước tái hiện (bước cuối của kịch bản; các bước chuẩn bị xem file bằng chứng):	
<pre>curl -i -X GET 'http://localhost:3000/api/categories/100' -H 'Content-Type: application/json' -H 'X-Student-Id: 23127060'</pre>	
Kết quả thực tế:	
<pre>HTTP/1.1 200 Content-Type: application/json; charset=utf-8 {"id":51,"name":"51b","shop":1,"id":52,"name":"52shop","id":53,"name":"53b","shop":1}</pre>	

Kết quả mong đợi: theo eshop-sut/README.md (FR-15).

Đề xuất sửa: Kiểm tra `category_id` tồn tại trước khi ghi, và khai báo `FOREIGN KEY (category_id) REFERENCES categories(id)` trong `database.js` kèm `PRAGMA foreign_keys = ON`.

C-11 — name và description không được sanitize - nguồn của stored XSS

Mức độ	● Medium
API	API-3
Vi phạm	SEC-04
Bằng chứng đầy đủ	bugs/evidence/C-11.md (evidence/C-11.md)

Ảnh hưởng: Payload `<script>` và `<img src=x onerror=>` được lưu nguyên văn vào CSDL và trả về nguyên văn. SEC-04 đòi dữ liệu người dùng nhập phải được escape khi hiển thị. **Giới hạn của phép kiểm này:** ở tầng API em chỉ chứng minh được **nửa nguồn** - rằng máy chủ lưu payload thô. Việc nó có thực sự chạy trên trình duyệt hay không còn phụ thuộc vào lớp hiển thị, phải kiểm riêng ở tầng giao diện.

Bước tái hiện (bước cuối của kịch bản, các bước chuẩn bị xem file bằng chứng):

```
curl -i -X GET 'http://localhost:3000/api/products/19'
-H 'Content-Type: application/json'
-H 'X-Student-Id: 23127060'
```

Kết quả thực tế:

```
HTTP/1.1 200
Content-Type: application/json; charset=utf-8

{"id":19,"name":"<script>alert('23127060')</script>","price":1000,"description":"<img src=
onerror=alert(1)>","imageUrl":"","category_id":1}
```

Kết quả mong đợi: theo eshop-sut/README.md (SEC-04).

Đề xuất sửa: Escape khi hiển thị (không dùng `dangerouslySetInnerHTML`), và lọc đầu vào ngay ở tầng API như một lớp phòng thủ thứ hai.

B-14 — checkout trả về 200 thay vì 201 Created

Mức độ	○ Low
API	API-2
Vi phạm	FR-08
Bằng chứng đầy đủ	bugs/evidence/B-14.md (evidence/B-14.md)

Ảnh hưởng: Thao tác tạo tài nguyên mới phải trả `201 Created`. Không gây hại trực tiếp nhưng phá vỡ quy ước REST và làm client khó phân biệt "đã tạo" với "đã có sẵn".

Bước tái hiện (bước cuối của kịch bản; các bước chuẩn bị xem file bằng chứng):

```
curl -i -X POST 'http://localhost:3000/api/checkout' \
  -H 'Content-Type: application/json' \
  -H 'X-Student-Id: 23127060' \
  -H 'Authorization: Bearer token3' \
  -d '{"total amount": 500000, "shipping address": "1 Le Loi"}'
```

Kết quả thực tế:

```
HTTP/1.1 200
Content-Type: application/json; charset=utf-8

{"message": "Checkout successful", "orderId": 116}
```

Kết quả mong đợi: theo eshop-sut/README.md (FR-08).

Đề xuất sửa: res.status(201).json({ ... });

C-12 — POST /api/products trả về 200 thay vì 201 Created

Mức độ	○ Low
API	API-3
Vi phạm	FR-15
Bằng chứng đầy đủ	bugs/evidence/C-12.md (evidence/C-12.md)

Ảnh hưởng: Cùng loại với B-14.

Bước tái hiện (bước cuối của kịch bản; các bước chuẩn bị xem file bằng chứng):

```
curl -i -X POST 'http://localhost:3000/api/products' \
  -H 'Content-Type: application/json' \
  -H 'X-Student-Id: 23127060' \
  -d '{"name": "Mũ trang thai 23127060", "price": 1000, "description": "x", "imageUrl": "x", "category_id": 11}'
```

Kết quả thực tế:

```
HTTP/1.1 200
Content-Type: application/json; charset=utf-8

{"message": "Product created", "id": 201}
```

Kết quả mong đợi: theo eshop-sut/README.md (FR 15).

Đề xuất sửa: res.status(201).json({ ... });

3. Công việc còn lại của em (HUMAN H3)

Đề bài mục 6.5 đòi mỗi bug phải được mở thành một GitHub Issue **kèm ảnh chụp màn hình**. Các file trong bugs/ISSUE_TEMPLATES/ đã sẵn sàng để dán thẳng lên GitHub:

1. Mở <https://github.com/<tai-khoan>/<repo>/issues/new>.

2. Dán nội dung `bugs/ISSUE_TEMPLATES/<ID>.md` (dòng đầu là tiêu đề Issue).

3. Gắn nhãn theo mức độ: `critical` / `high` / `medium` / `low`, kèm nhãn `api-1` / `api-2` / `api-3`.

4. Chụp màn hình Issue vừa tạo, lưu vào `bugs/screenshots/<ID>.png`.

5. Điền số hiệu Issue vào cột **GitHub Issue** của bảng ở mục 1.

Em ưu tiên mở Issue cho 12 bug Critical trước nếu không đủ thời gian làm hết.